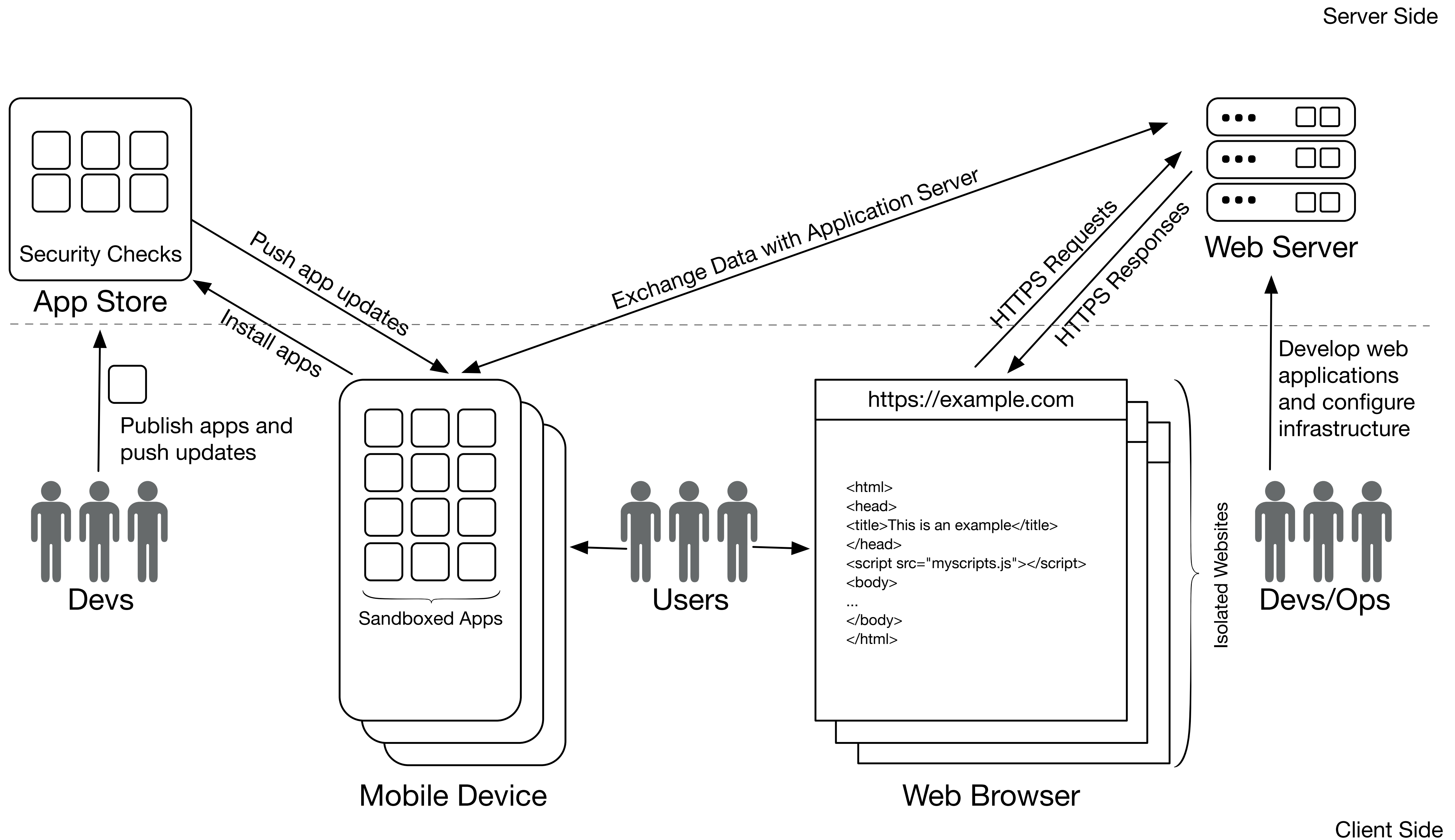


Introduction to Web Security

Dr. Ramokapane



URLs

scheme://credentials@host:port/resourcepath?query_parameters#fragments

Segment	Optional	Description
scheme:	○	Indicates the protocol a web client should use to retrieve a resource. Common protocols in the web are http: and https:
//	○	Indicates a hierarchical URL as required by [12]
credentials@	●	Can contain a username and password that might be needed to retrieve a resource from a remote server.
host	○	Specifies a case-insensitive DNS name (e. g. <i>cybok.org</i>), a raw IPv4 (e. g. <i>127.0.0.1</i>) or IPv6 address (e. g. <i>[0:0:0:0:0:0:0:1]</i>) to indicate the location of the server hosting a resource.
:port	●	Describes a non-default network port number to connect to a remote server. Default ports are 80 for HTTP and 443 for HTTPS.
/resourcepath	○	Identifies the resource address on a remote server. The resource path format is built on top of Unix directory semantics.
?query_parameters	●	Passes non-hierarchical parameters to a remote resource, such as server-side script input parameters.
#fragment	●	Provides instructions for the browser. In practice, it is used to address an HTML anchor element for in-document navigation.

HTTP

HTTP/1.1

<name>:<value>

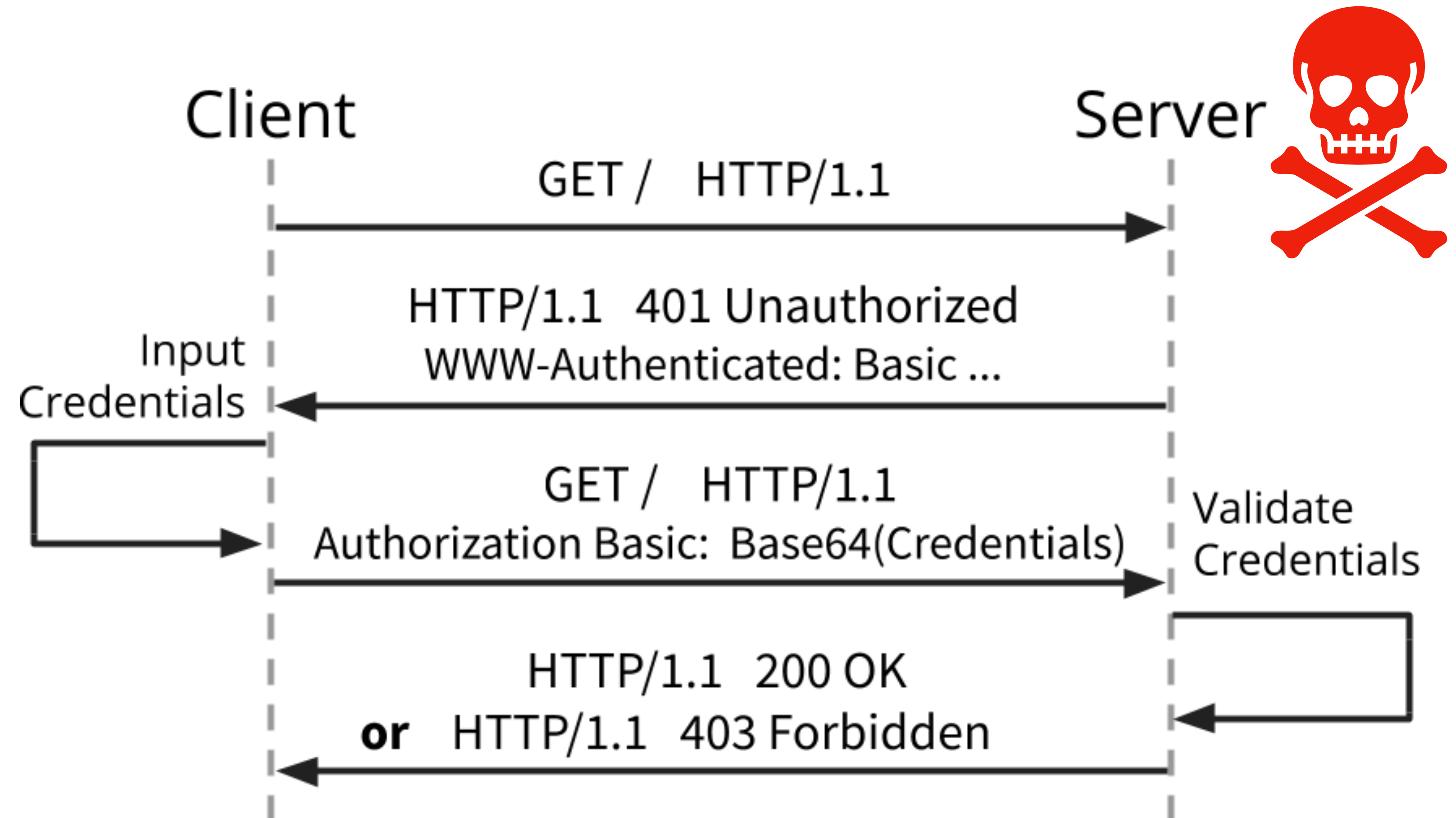
User-Agent:

URL:

Content-Length

Content-Type

...



Basic vs. POST

Cookies

Set-Cookie: name=value

Cookie: name=value

Web Sockets

Upgrade: WebSocket

Pull and push!

HTML

Domain Object Model (DOM)

Lack of adherence to standard
across browser implementations

Variation in parsing behaviours
and error recovery

Failure to properly encode
reserved characters when
displaying user-controlled
information



CSS

Aim is to provide a simple way to
manipulate the appearance of
HTML documents

Address the inconsistencies in
vendor implementations

Allow HTML tags to be scaled,
positioned or decorated without
being limited by the original
HTML markup constraints



JavaScript

Object-oriented language

Interpreted

Client side? Server side?

Wide variety of I/O mechanisms

Network access

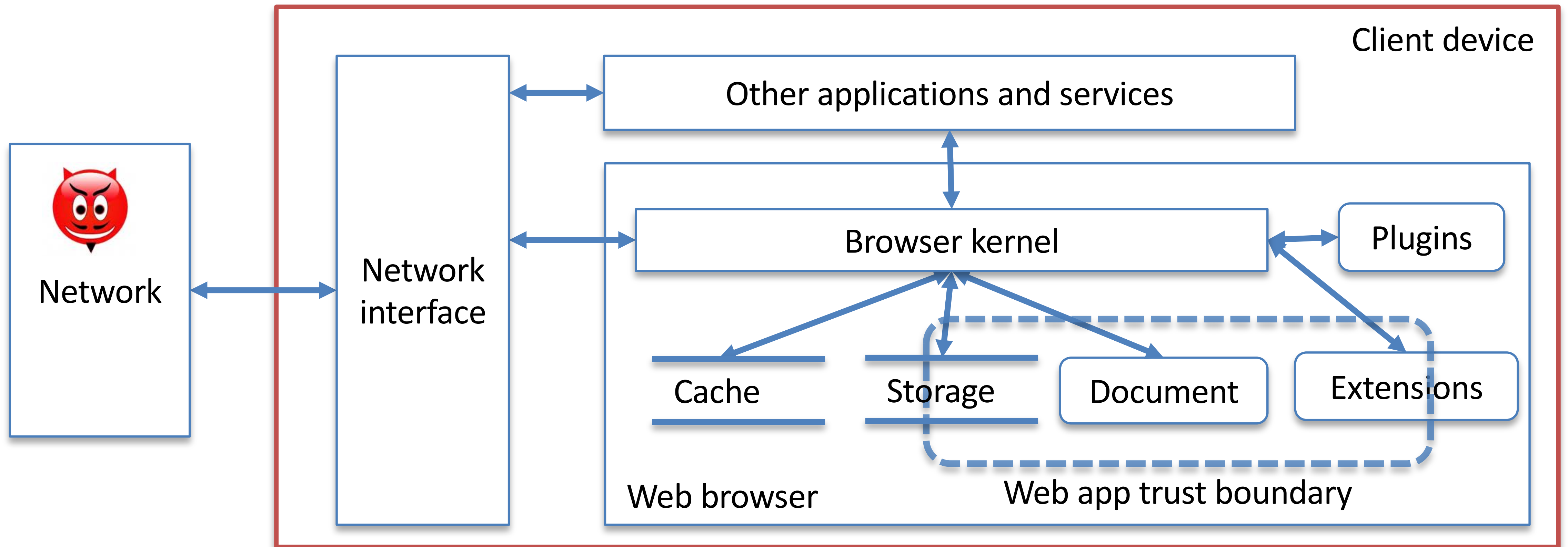
File access

Example: node.js

Doesn't support I/O mechanisms

Reliant on predefined interfaces in
native code in the browser

Sandboxing



Client Side JavaScript

Every HTML document in a browser has its own JavaScript *Execution Context*
which means?

All scripts in a document context share the same sandbox

All JavaScript blocks in a context are executed individually and in a *well-defined order*

Execution contexts are strictly isolated from each other

What about inter-context communication?

Through browser-specific APIs

Client Side JavaScript

Parsing validates the script syntax and translates to an intermediary binary representation for performance reasons

Code has no effect until parsing is completed

Blocks with syntax errors are ignored and the next block is parsed

Function resolution registers all named, global functions the parser found in a block

All registered functions can be reached from the following code

Execution run all code statements outside of function blocks

Exceptions may still lead to runtime failures



Same-Origin-Policy (SOP)

A mechanism for *content isolation*

Two separate JavaScript execution contexts are only allowed to manipulate a document's DOM if there is an exact match between the document host and the protocol, DNS name and port numbers

Origin <protocol, DNS name, port>



Originating document	Accessed document	Browser behaviour
https://www.cybok.org/ docs/	https://www.cybok.org/ scripts/	Access okay
https://www.cybok.org/	https:// books .cybok.org/	Host mismatch
http ://www.cybok.org/	https ://www.cybok.org/	Protocol mismatch
https://www.cybok.org/	https://www.cybok.org: 10443 /	Port mismatch

Content Security Policy (CSP)

Allows web developers and server operators to limit the number of origins that browsers should consider to be trusted sources of content – including executable code and media files.

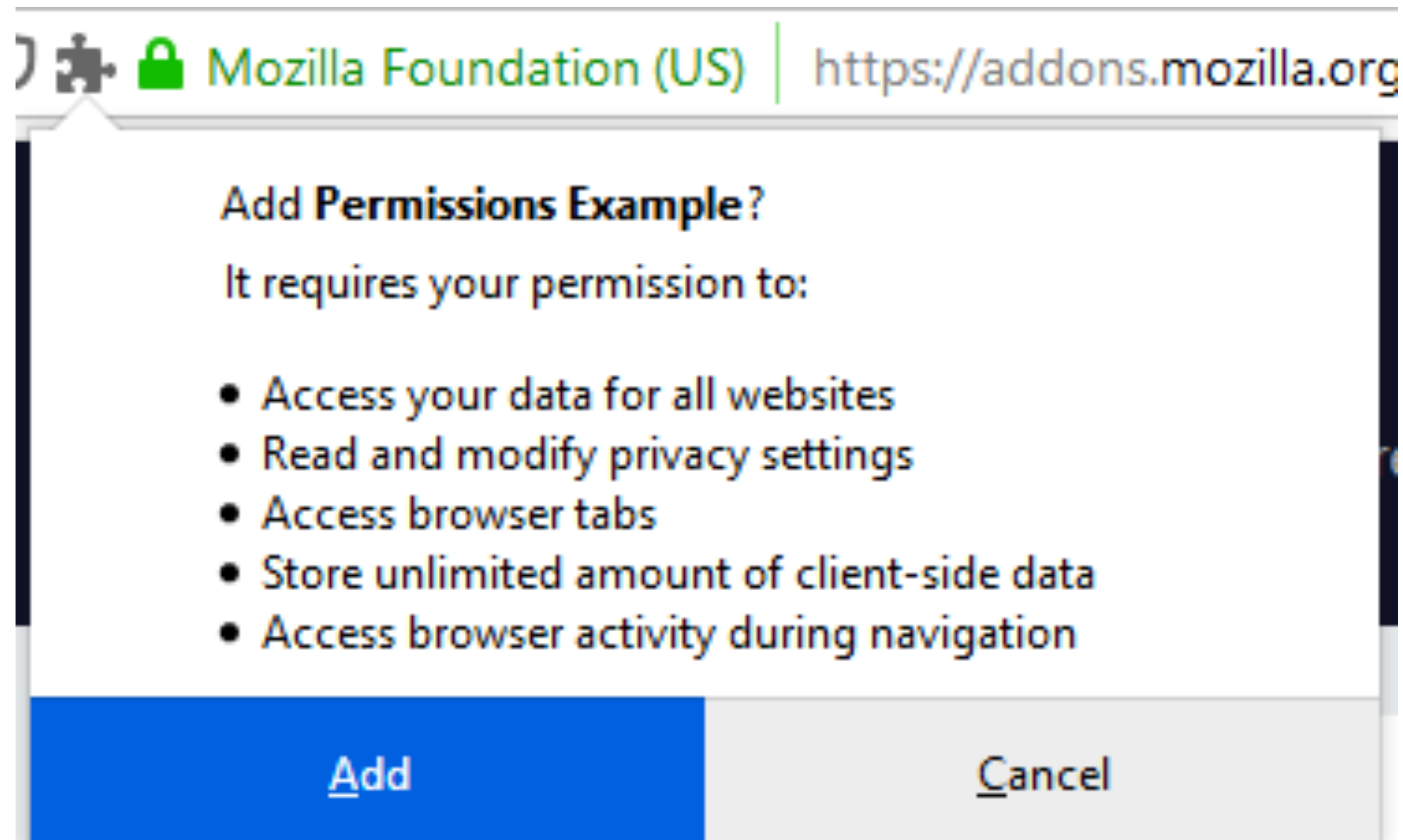
Servers can globally disable code execution on the client.

Can either configure a web server to send a Content-Security-Policy HTTP response header or add a HTML <meta> tag to a website.

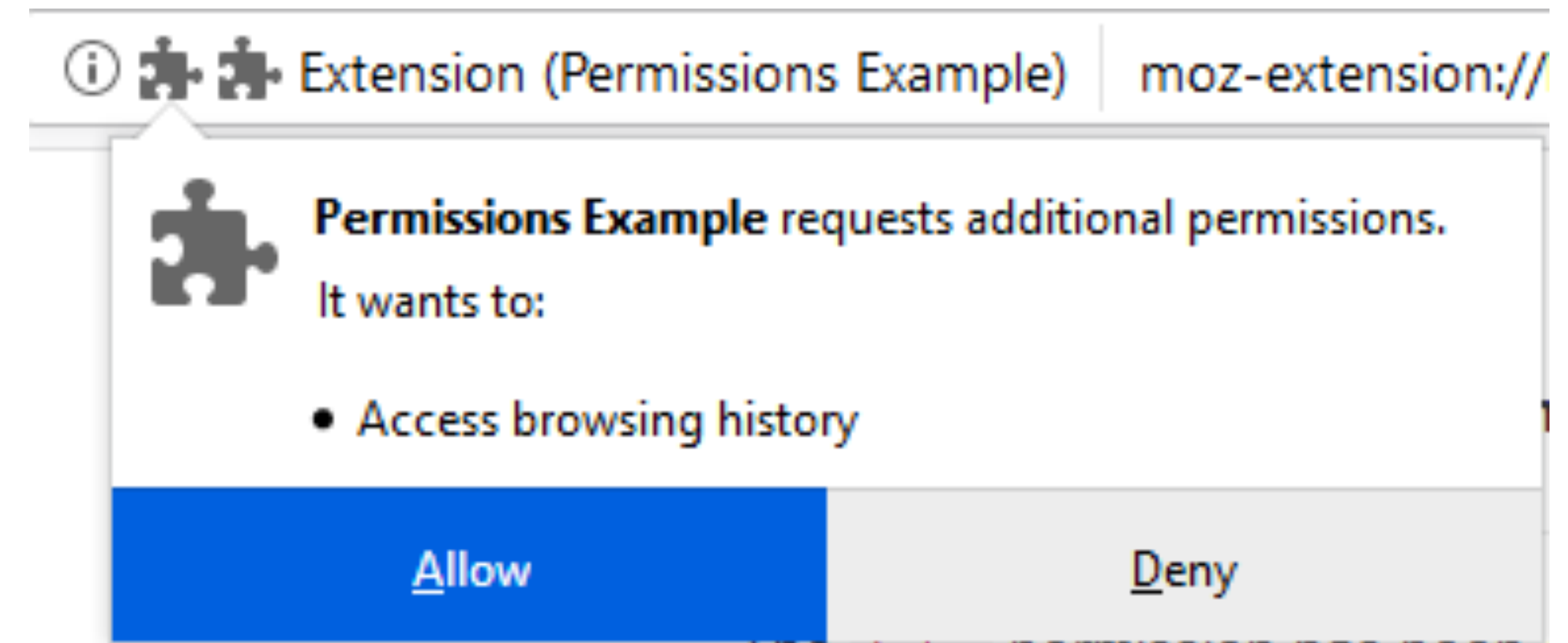
Compatible browsers will then only execute code or load media files from trusted origins.

**Content-Security-Policy: default-src 'self'; img-src *;
media-src trusted-media.com; script-src trusted-scripts.com**

Permissions



(a) Install permissions



(b) Runtime permissions



Issues with over-permissioning

Cookies



Web servers can associate stateful information via cookies.

which means?

Cookie information (e.g., IDs of items added to the shopping cart in an online shop) is stored by the client.

Allow clients and servers to include their unique session identifiers in each HTTP request-response, avoiding the need for repeated authentication.

Session cookies expire when the session is closed (e.g., by the client closing the browser) but persistent cookies only expire after a specific time.

Cookie-based authentication allows clients to re-establish sessions every time they send requests to the server with a valid cookie.

HTTP vs. HTTPS



Your connection is not private

Attackers might be trying to steal your information from **self-signed.badssl.com** (for example, passwords, messages, or credit cards). [Learn more](#)

NET::ERR_CERT_AUTHORITY_INVALID

☐ Help improve Safe Browsing by sending some [system information and page content](#) to Google.
[Privacy policy](#)

Advanced

Back to safety



(a) Warning message for invalid certificate in Chrome

⚠ Not secure | [https://](#)

(b) Invalid certificate

🔒 [https://](#)

(c) Valid and trusted certificate

🔒 Comodo Security Solutions, Inc. [US] | [https://](#)

(d) Extended validation certificate

WebViews

Easy integration of web content into mobile apps

Mobile apps can invoke JavaScript from within the web content and monitor and intercept events in the web content.

JavaScript APIs allow WebView apps to interact with content and sensors outside the WebView context.



App-to-Web Attacks

Malicious app injects JavaScript into hosted WebViews

Extract sensitive data

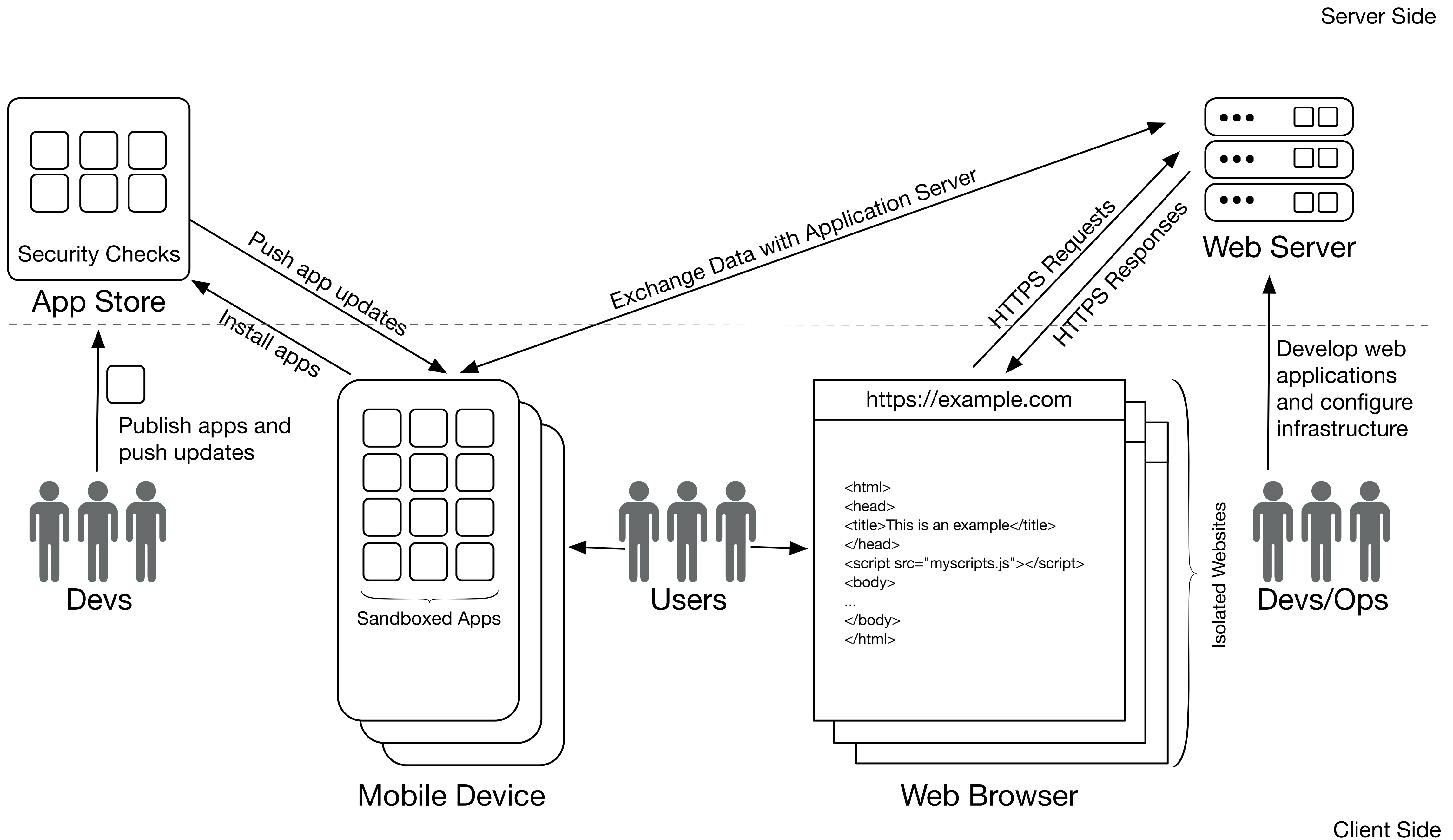
Trick WebViews into navigating to and presenting users with malicious websites

Web-to App Attacks

Inject untrusted web content into an app

Leverage the JavaScript Bridge to to the underlying host app

Privilege escalation to the hosting app's process



Further Reading

Listen to this podcast: <https://www.cybok.org/events/web-mobile-security-podcast>

CyBOK - Web and Mobile Security Knowledge Area (on which this lecture is based): https://www.cybok.org/media/downloads/Web_Mobile_Security_v1.0.1.pdf